Extração estruturada de vulnerabilidades

A partir de relatórios PDF de scanners de segurança, com o modelo rodando dentro da organização.

Beatriz Machado · Cristhian Kapelinski · Guilherme Klauberg

UNIPAMPA · Inteligência Artificial Aplicada



O PROBLEMA

O relatório entra como texto, não como dado

1. **Um formato por ferramenta**
   Summary no OpenVAS, Synopsis no Nessus: nada em comum

2. **Triagem é leitura manual**
   Consolidar, comparar e priorizar exige transcrever à mão

3. **A nuvem não é saída fácil**
   O relatório é o mapa da superfície de ataque: hosts, portas, falhas



OBJETIVO

Um PDF entra. Um esquema único sai.

Dez campos comuns a todos os scanners:

`nome` `severidade` `host` `porta`
`protocolo` `descrição` `solução`
`impacto` `referências` `origem`

Quatro scanners no escopo: OpenVAS, Qualys, Nessus e ZAP.



ARQUITETURA

Pipeline fixo, modelo trocável

1. **PDF**
   Relatório do scanner
2. **Texto**
   Texto limpo extraído
3. **Blocos**
   Um bloco por achado, com id fixo
4. **LLM**
   Lotes de blocos com esquema JSON
5. **Consolida**
   Normaliza e funde duplicatas
6. **Dados**
   Um registro por achado

O relatório sai do scanner em PDF, no layout e no vocabulário daquela ferramenta.

ARQUITETURA

Pipeline fixo, modelo trocável

1. **PDF**
   Relatório do scanner
2. **Texto**
   Texto limpo extraído
3. **Blocos**
   Um bloco por achado, com id fixo
4. **LLM**
   Lotes de blocos com esquema JSON
5. **Consolida**
   Normaliza e funde duplicatas
6. **Dados**
   Um registro por achado

O texto é extraído do PDF, sem depender de como a página foi desenhada.

ARQUITETURA

Pipeline fixo, modelo trocável

1. **PDF**
   Relatório do scanner
2. **Texto**
   Texto limpo extraído
3. **Blocos**
   Um bloco por achado, com id fixo
4. **LLM**
   Lotes de blocos com esquema JSON
5. **Consolida**
   Normaliza e funde duplicatas
6. **Dados**
   Um registro por achado

O texto é cortado em um bloco por achado pela configuração do scanner.
A contagem fica fixa aqui, antes de qualquer chamada ao modelo.

ARQUITETURA

Pipeline fixo, modelo trocável

1 **PDF**
Relatório do scanner

2 **Texto**
Texto limpo extraído

3 **Blocos**
Um bloco por achado, com id fixo

4 **LLM**
Lotes de blocos com esquema JSON

5 **Consolida**
Normaliza e funde duplicatas

6 **Dados**
Um registro por achado

Blocos inteiros são agrupados em lotes, sem partir bloco ao meio; os lotes cuja resposta falha voltam em pacotes menores.

ARQUITETURA

Pipeline fixo, modelo trocável

1 **PDF**
Relatório do scanner

2 **Texto**
Texto limpo extraído

3 **Blocos**
Um bloco por achado, com id fixo

4 **LLM**
Lotes de blocos com esquema JSON

5 **Consolida**
Normaliza e funde duplicatas

6 **Dados**
Um registro por achado

As duplicatas identificadas são consolidadas, para não sobrar registro repetido.

ARQUITETURA

Pipeline fixo, modelo trocável

1 **PDF**
Relatório do scanner

2 **Texto**
Texto limpo extraído

3 **Blocos**
Um bloco por achado, com id fixo

4 **LLM**
Lotes de blocos com esquema JSON

5 **Consolida**
Normaliza e funde duplicatas

6 **Dados**
Um registro por achado

Sai um registro por achado, em um esquema unificado, pronto para consultar e exportar.

DECISÕES DE IA

Três escolhas, três motivos

GERAR, NÃO ROTULAR

A saída não está no texto

Solução, impacto e severidade exigem reescrever o bloco.

AJUSTAR, NÃO SÓ PEDIR

Treino barato, formato rígido

Os rótulos vêm da própria ferramenta, sem anotação manual.

LOCAL, NÃO NUVEM

O dado não sai de casa

Dever de proteger a infraestrutura (LGPD, art. 46).

A pergunta do projeto: **modelos pequenos, dentro da organização, dão conta da tarefa?**

DADOS

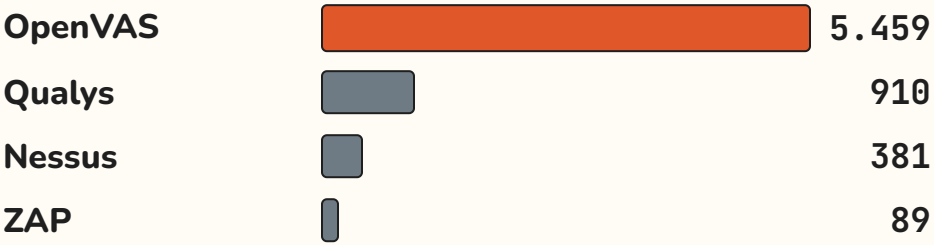
O gabarito vem da própria ferramenta

136
relatórios: PDF + exportação de máquina

6.841
exemplos · 6.187 treino / 654 validação

Zero anotação manual
Pareamento por host + id do achado; separação treino/teste por aplicação

EXEMPLOS DE TREINO POR SCANNER



80% é OpenVAS: a avaliação é reportada por scanner, não só agregada.

PLANO EXPERIMENTAL

Nuvem, local e local ajustado

TETO

Nuvem

DeepSeek-V4-Flash, few-shot

Qual é a melhor qualidade possível?

COMPARAÇÃO

Local

O mesmo pipeline, modelo dentro da organização

Quanto se perde ao trazer para dentro?

SISTEMA PROPOSTO

Local ajustado

QLoRA em 4 bits, servido com esquema

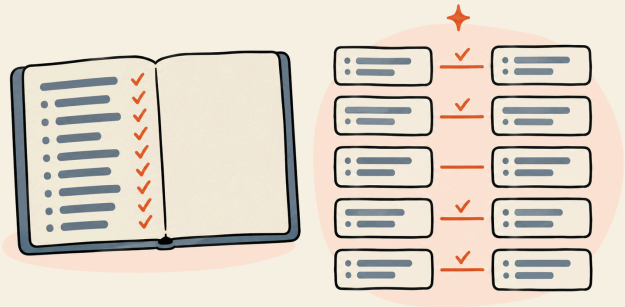
O ajuste recupera a diferença?

Todos sobre a mesma tarefa e o mesmo pipeline, com teste separado por aplicação e um corte de **scanner não visto**.

AVALIAÇÃO

Cobertura e conteúdo, medidos separado

Cobertura	O achado virou registro? Recall de blocos
Determinísticos	Acerto exato em host, porta, protocolo e CVSS
Narrativos	Similaridade lexical e semântica
Severidade	Macro-F1 por classe
Robustez e custo	Esquema, tempo, VRAM e tokens



PLANEJAMENTO

Oito etapas: o sistema sem IA primeiro

01
Dados
Pareamento e separação congelada

02
Baseline
Extrator por regras, o piso

03
Pipeline
Segmentação, chamada, métricas

04
Teto
Modelo de nuvem

05
Seleção
Modelos locais: primário e controle

06
Ajuste fino
Treino QLoRA

07
Experimentos
Repetições e scanner não visto

08
Fechamento
Resultados e documentação

Primeiro, as três etapas que entregam o sistema completo **sem IA**: o piso de comparação.

PLANEJAMENTO

Depois, os modelos entram e são comparados

01
Dados
Pareamento e separação congelada

02
Baseline
Extrator por regras, o piso

03
Pipeline
Segmentação, chamada, métricas

04
Teto
Modelo de nuvem

05
Seleção
Modelos locais: primário e controle

06
Ajuste fino
Treino QLoRA

07
Experimentos
Repetições e scanner não visto

08
Fechamento
Resultados e documentação

Depois, os modelos entram, terminando no corte com **scanner não visto**.

PRÓXIMOS PASSOS

Do piso sem IA até o modelo ajustado

1. **Rodar o teto em nuvem**
   Referência de qualidade no mesmo pipeline
2. **Selecionar modelos locais**
   Um primário e um de controle
3. **Ajustar e comparar**
   Modelo base contra ajustado em 4 bits
4. **Experimentos**
   Repetições e scanner não visto

